

MANUAL COMPLETO DE NMAP

Guía para Principiantes en Ciberseguridad

Desde cero hasta el escaneo profesional de redes

Ingeniería de Sistemas y Ciberseguridad

© 2024 — Guía de Referencia

0. Antes de Empezar: ¿Qué necesito saber?

Este manual está diseñado para personas que nunca han usado Nmap o que tienen experiencia mínima en redes. No necesitas ser experto, solo tener curiosidad y seguir los pasos con calma.

0.1 ¿Qué es una Red?

Una red es un conjunto de computadoras y dispositivos conectados entre sí para compartir información. Imagina que cada casa de un barrio tiene una dirección única; en redes, esa 'dirección' se llama dirección IP (ejemplo: 192.168.1.5).

Cuando te conectas a tu WiFi en casa, tu computadora recibe una IP dentro de un rango, como 192.168.1.0/24. Todos los dispositivos en ese 'barrio digital' forman tu red local.

0.2 ¿Qué son los Puertos?

Piensa en una computadora como un edificio de apartamentos. La dirección IP sería la dirección del edificio, y los puertos serían los números de apartamento. Cada servicio 'vive' en un puerto diferente:

- El apartamento 80 es donde vive el servicio web (HTTP).
- El apartamento 22 es donde vive el acceso remoto seguro (SSH).
- El apartamento 443 es donde viven los sitios HTTPS (seguros).

Existen 65,535 puertos en total. Nmap nos ayuda a 'tocar la puerta' de cada uno para saber qué hay adentro.

0.3 ¿Qué es una Auditoría de Seguridad?

Una auditoría de seguridad es una revisión autorizada de una red o sistema para encontrar vulnerabilidades antes de que lo hagan personas maliciosas. Es como contratar a un cerrajero experto para que intente entrar a tu casa y te diga qué cerraduras son débiles.

⚠ **NOTA: IMPORTANTE LEGAL:** Nunca escanees redes o dispositivos sin autorización escrita del propietario. Hacerlo sin permiso es un delito en casi todos los países, incluyendo Colombia (Ley 1273 de 2009).

0.4 ¿Cómo instalar Nmap?

Nmap es gratuito y está disponible para todos los sistemas operativos:

En Windows:

1. Ve a <https://nmap.org/download.html>
2. Descarga el instalador .exe para Windows.
3. Ejecuta el instalador y acepta todas las opciones por defecto (incluye Zenmap, la interfaz gráfica).
4. Abre la terminal de Windows (CMD o PowerShell) y escribe: `nmap --version`

En Linux (Ubuntu/Debian/Kali):

```
sudo apt update && sudo apt install nmap -y
```

En macOS:

```
brew install nmap
```

✓ **CONSEJO:** Kali Linux ya trae Nmap instalado por defecto. Si estás aprendiendo ciberseguridad, Kali es la distribución recomendada.

1. ¿Qué es Nmap?

Nmap (Network Mapper) es una herramienta de código abierto y gratuita, creada en 1997 por Gordon Lyon (alias Fyodor). Es la herramienta de exploración de redes más utilizada en el mundo por administradores de sistemas, auditores de seguridad y equipos de respuesta a incidentes.

A diferencia de un simple 'ping' que solo dice si un equipo está encendido, Nmap puede descubrir qué servicios están corriendo, qué versión tienen, qué sistema operativo usa la máquina, y mucho más.

1.1 ¿Qué puede hacer Nmap exactamente?

- **Descubrir hosts activos:** Saber qué equipos están encendidos en una red.
- **Escanear puertos:** Ver qué 'puertas' están abiertas en cada equipo.
- **Detectar servicios y versiones:** Identificar qué software corre en cada puerto.
- **Detectar el sistema operativo:** Adivinar si el equipo usa Windows, Linux, etc.
- **Detectar vulnerabilidades:** Mediante scripts, buscar fallos conocidos.
- **Mapear redes completas:** Hacer inventario de toda la infraestructura.

1.2 El Handshake TCP: La Base de Todo

Para entender cómo Nmap 'habla' con los equipos, necesitas conocer el protocolo TCP y su famoso 'apretón de manos' (handshake). Este es el proceso que ocurre cuando dos computadoras quieren comunicarse:

5. **SYN (Synchronize):** El cliente envía un paquete diciendo 'Hola, quiero conectarme'.
6. **SYN-ACK:** El servidor responde 'Recibido, estoy listo para la conexión'.
7. **ACK (Acknowledge):** El cliente confirma 'Perfecto, empecemos a hablar'.

Una vez completado el handshake, la conexión está establecida. Nmap puede manipular este proceso para obtener información sin completar la conexión (lo cual es más sigiloso).

Si un puerto está cerrado, el servidor responde con RST (Reset), que es como decir 'aquí no hay nadie, vete'. Si hay un firewall bloqueando, simplemente no responde nada.

✓ **CONSEJO:** Analogía: El handshake es como llamar a una puerta. SYN=tocas la puerta, SYN-ACK=alguien responde '¿quién es?', ACK=tú dices tu nombre. Si nadie responde=firewall. Si escuchas 'aquí no vive nadie'=puerto cerrado.

2. Los 6 Estados de un Puerto

Este es uno de los conceptos más importantes para principiantes. Nmap no simplemente dice 'abierto' o 'cerrado': tiene 6 estados posibles, y cada uno te dice algo diferente sobre la red.

ESTADO	¿QUÉ SIGNIFICA?	¿QUÉ HAGO CON ESTO?
Closed (Cerrado)	El puerto responde, pero no hay ninguna aplicación activa.	Menos urgente, pero indica que el firewall no lo bloquea.
Filtered (Filtrado)	Un firewall bloquea los paquetes. Nmap no puede saber si está abierto.	Hay una capa de protección; intenta técnicas de evasión.
Unfiltered	El puerto responde, pero no se puede determinar si está abierto o cerrado.	Requiere más análisis con otros tipos de escaneo.
Open Filtered	Nmap no recibe respuesta, podría estar abierto o filtrado.	Común en escaneos UDP. Requiere más investigación.
Closed Filtered	Nmap no puede determinar el estado con certeza.	Ocurre solo en escaneos de tipo Idle (avanzado).

⚠ NOTA: Para un principiante, los estados más importantes son Open (requiere atención inmediata) y Filtered (hay protección activa). Los demás los irás entendiendo con la práctica.

2.1 ¿Cómo interpretar un resultado de Nmap?

Cuando ejecutas Nmap, verás una salida similar a esta:

```
PORT      STATE    SERVICE  VERSION
22/tcp    open     ssh      OpenSSH 8.2p1
80/tcp    open     http     Apache httpd 2.4.41
443/tcp   open     https    Apache httpd 2.4.41
3306/tcp  filtered mysql
8080/tcp  closed   http-proxy
```

Esto nos dice:

- Puerto 22: Hay un servidor SSH (acceso remoto) corriendo OpenSSH versión 8.2p1.
- Puertos 80 y 443: Hay un servidor web Apache activo.
- Puerto 3306: MySQL está detrás de un firewall (no podemos saber si está activo).
- Puerto 8080: No hay ningún proxy activo aquí.

3. Comandos y Flags de Nmap

Las 'flags' son parámetros que le dicen a Nmap cómo comportarse. Se escriben después del comando nmap, precedidas de un guión (-) o doble guión (--).

La estructura básica de un comando Nmap es:

```
nmap [opciones/flags] [objetivo]
```

Donde el objetivo puede ser una IP (192.168.1.1), un dominio (ejemplo.com) o un rango de IPs (192.168.1.0/24).

3.1 Mi Primer Escaneo

Empieza con esto: escanear tu propia máquina (siempre es legal y seguro).

```
nmap localhost
# o también:
nmap 127.0.0.1
```

Esto te mostrará qué puertos tiene abiertos TU propia computadora. Es un excelente ejercicio de aprendizaje.

3.2 Técnicas de Escaneo de Puertos

Estas flags controlan CÓMO Nmap envía los paquetes para detectar si un puerto está abierto.

FLAG	NOMBRE	DESCRIPCIÓN PARA PRINCIPIANTES	¿CUÁNDO USARLO?
-sS	TCP SYN Scan	El más común y sigiloso. Envía un SYN y espera la respuesta, pero nunca completa el handshake. Rápido y no deja logs en la mayoría de aplicaciones.	Escaneo general (requiere permisos de administrador/root)
-sT	TCP Connect Scan	Hace la conexión TCP completa. Más lento y ruidoso, pero no requiere permisos especiales.	Cuando no tienes permisos de root/admin
-sU	UDP Scan	Escanea puertos UDP (como DNS, DHCP). Muy lento porque UDP no confirma recepciones.	Cuando buscas servicios como DNS (53) o SNMP (161)
-sV	Version Detection	Intenta identificar qué versión exacta del software corre en cada puerto abierto.	Siempre que quieras saber versiones para buscar CVEs
-O	OS Detection	Analiza las respuestas para adivinar el sistema operativo del objetivo.	Cuando necesitas saber si el objetivo usa Windows o Linux
-A	Aggressive Scan	Activa -sV, -O, scripts por defecto y traceroute en un solo comando.	Auditorías completas (es más ruidoso)
-sn	Ping Scan	Solo detecta qué hosts están activos en la red, sin escanear puertos.	Hacer inventario rápido de la red

3.3 Selección de Puertos

Por defecto, Nmap escanea los 1000 puertos más comunes. Puedes modificar esto:

FLAG	EJEMPLO	¿QUÉ HACE?
-p [puerto]	-p 80	Escanea solo el puerto 80
-p [rango]	-p 1-1000	Escanea del puerto 1 al 1000
-p [lista]	-p 22,80,443,3306	Escanea esos puertos específicos
-p-	-p-	Escanea TODOS los 65,535 puertos
--top-ports [n]	--top-ports 100	Escanea los N puertos más comunes

✓ **CONSEJO:** Para principiantes: comienza con los 1000 puertos por defecto. Cuando quieras ser exhaustivo, usa -p- (pero tardará más tiempo).

3.4 Control de Velocidad: El Parámetro -T

El parámetro -T (timing) controla qué tan rápido o lento envía paquetes Nmap. Esto es crítico: más rápido = más ruidoso y más chance de ser detectado.

NIVEL	NOMBRE	VELOCIDAD	¿CUÁNDO USARLO?
-T0	Paranoid	Extremadamente lento (minutos entre paquetes)	Evadir IDS altamente sensibles
-T1	Sneaky	Muy lento	Redes con detección de intrusos activa
-T2	Polite	Lento	Minimizar uso de ancho de banda
-T3	Normal	Velocidad por defecto de Nmap	Uso general
-T4	Aggressive	Rápido	Redes locales rápidas y confiables
-T5	Insane	Extremadamente rápido	Solo en pruebas de laboratorio

⚠ **NOTA:** Para aprender: usa -T3 (defecto) o -T4 en tu red local de práctica. Nunca uses -T5 en redes de producción.

3.5 Opciones de Salida y Resultados

Siempre guarda los resultados de tus auditorías. Estos son los formatos disponibles:

FLAG	FORMATO	DESCRIPCIÓN	¿CUÁNDO USARLO?
-oN resultado.txt	Normal	Texto legible para humanos, igual a lo que ves en pantalla.	Leer y revisar manualmente

FLAG	FORMATO	DESCRIPCIÓN	¿CUÁNDO USARLO?
-oX resultado.xml	XML	Formato estructurado que pueden leer otras herramientas como Metasploit.	Importar en otras herramientas
-oG resultado.grep	Grepable	Formato de una línea por host, fácil de filtrar con grep/awk.	Análisis con scripts de Linux
-oA nombre_base	Todos	Genera los tres formatos anteriores simultáneamente.	Auditorías formales donde necesitas evidencia completa
-v / -vv	Verbose	Muestra más detalles mientras escanea en tiempo real.	Ver el progreso del escaneo
--open	Solo abiertos	Muestra solo los puertos con estado 'open'.	Filtrar resultados rápidamente

4. Nmap Scripting Engine (NSE): El Superpoder de Nmap

El NSE es un sistema de scripts escritos en el lenguaje Lua que extiende las capacidades de Nmap enormemente. Con NSE, Nmap puede hacer tareas muy específicas: detectar vulnerabilidades, probar contraseñas, obtener información de servicios, y más.

Nmap trae más de 600 scripts preinstalados. Puedes verlos en `/usr/share/nmap/scripts/` en Linux.

4.1 ¿Cómo usar los scripts?

La forma más simple es activar los scripts por defecto con `-sC`:

```
nmap -sC 192.168.1.1
```

Para usar un script específico:

```
nmap --script nombre-del-script 192.168.1.1
```

Para usar múltiples scripts o categorías:

```
nmap --script 'vuln,safe' 192.168.1.1
```

```
nmap --script 'http-*' 192.168.1.1 # todos los scripts que empiecen con http-
```

4.2 Categorías de Scripts NSE

Los scripts están organizados en categorías según su propósito:

CATEGORÍA	¿QUÉ HACE?	EJEMPLO DE USO	NIVEL DE RIESGO
auth	Prueba autenticaciones: contraseñas por defecto, acceso anónimo.	Detectar FTP anónimo activo	Bajo
default (-sC)	Scripts básicos y seguros de reconocimiento. Activos con <code>-A</code> o <code>-sC</code> .	Obtener información básica del servicio	Bajo
discovery	Descubre información adicional: tablas ARP, servicios de directorio, etc.	Enumerar recursos compartidos SMB	Bajo
safe	Scripts que no afectan negativamente al objetivo. Equivalentes a solo lectura.	Cualquier reconocimiento pasivo	Mínimo
vuln	Busca vulnerabilidades conocidas (CVE) en los servicios detectados.	Detectar EternalBlue en SMB	Medio
exploit	Intenta explotar activamente una vulnerabilidad. Puede causar daños.	Solo en entornos de prueba autorizados	Alto

CATEGORÍA	¿QUÉ HACE?	EJEMPLO DE USO	NIVEL DE RIESGO
brute	Ataques de fuerza bruta contra protocolos de autenticación.	Probar contraseñas en SSH/FTP	Alto
malware	Detecta malware o backdoors en el objetivo.	Buscar puertas traseras en servicios	Bajo
intrusive	Scripts que pueden afectar o crashear el servicio objetivo.	Solo en laboratorios controlados	Muy alto

⚠ NOTA: Las categorías 'exploit', 'brute' e 'intrusive' NUNCA deben usarse sin autorización explícita y documentada del propietario del sistema.

4.3 Scripts Más Útiles para Principiantes

Scripts HTTP/Web:

```
nmap --script http-title -p 80,443 192.168.1.0/24
```

Obtiene el título de las páginas web en toda la red.

```
nmap --script http-headers -p 80 192.168.1.1
```

Muestra las cabeceras HTTP del servidor (revela versiones de software).

```
nmap --script http-methods -p 80,443 192.168.1.1
```

Lista los métodos HTTP permitidos (GET, POST, PUT, DELETE...).

Scripts SSH:

```
nmap --script ssh-hostkey -p 22 192.168.1.1
```

Obtiene la clave pública del servidor SSH (útil para verificar identidad).

```
nmap --script ssh-auth-methods -p 22 192.168.1.1
```

Muestra qué métodos de autenticación acepta el SSH (contraseña, clave, etc.).

Scripts SMB/Windows:

```
nmap --script smb-os-discovery -p 445 192.168.1.1
```

Obtiene información del sistema operativo Windows mediante SMB.

```
nmap --script smb-security-mode -p 445 192.168.1.1
```

Verifica la configuración de seguridad del servicio SMB.

Scripts de Vulnerabilidades:

```
nmap --script vuln -p 445 192.168.1.1
```

Busca todas las vulnerabilidades conocidas en el puerto 445 (SMB).

```
nmap -p 445 --script smb-vuln-ms17-010 192.168.1.0/24
```

Busca específicamente EternalBlue (MS17-010) en toda la red.

5. Técnicas de Evasión de Firewalls e IDS

En auditorías reales, los sistemas tienen firewalls y sistemas de detección de intrusos (IDS) que pueden bloquear o detectar el escaneo. Nmap ofrece técnicas para evadir estas defensas (siempre con autorización).

5.1 ¿Qué es un Firewall?

Un firewall es un sistema que filtra el tráfico de red según reglas predefinidas. Puede bloquear paquetes basándose en la IP de origen, el puerto, el protocolo, o incluso el contenido del paquete.

Un IDS (Intrusion Detection System) es un sistema que analiza el tráfico en busca de patrones sospechosos y genera alertas cuando detecta algo anormal, como un escaneo de puertos.

5.2 Técnicas de Evasión

FLAG	TÉCNICA	¿CÓMO FUNCIONA?	EJEMPLO
-f	Fragmentación de paquetes	Divide los paquetes en fragmentos pequeños (8 bytes). Los IDS simples no pueden reensamblarlos para analizarlos.	<code>nmap -f 192.168.1.1</code>
--mtu [n]	MTU personalizada	Define el tamaño máximo de fragmento. Debe ser múltiplo de 8. Permite control más fino de la fragmentación.	<code>nmap --mtu 24 192.168.1.1</code>
-D RND:10	Señuelos (Decoys)	Mezcla tu IP real con 10 IPs aleatorias. El log del servidor muestra 11 'atacantes' simultáneos, ocultando cuál es real.	<code>nmap -D RND:10 192.168.1.1</code>
-D IP1,IP2,ME	Señuelos específicos	Igual que el anterior, pero con IPs concretas. ME indica tu posición en la lista.	<code>nmap -D 10.0.0.1,10.0.0.2,ME 192.168.1.1</code>
-S [IP_falsa]	Spoofing de IP	Falsifica la IP de origen. El servidor responde a la IP falsa, no a ti. Requiere otra forma de capturar respuestas.	<code>nmap -S 192.168.1.100 192.168.1.1</code>
--source-port 53	Puerto de origen	Muchos firewalls permiten todo el tráfico proveniente del puerto 53 (DNS) o 80 (HTTP) por reglas mal configuradas.	<code>nmap --source-port 53 192.168.1.1</code>
--data-length 25	Relleno de datos	Añade 25 bytes de datos aleatorios a los paquetes. Los hace parecer tráfico legítimo en lugar de paquetes de escaneo.	<code>nmap --data-length 25 192.168.1.1</code>
--randomize-hosts	Aleatorizar objetivos	Cuando escaneas múltiples hosts, los visita en orden aleatorio en lugar de secuencial, evitando patrones obvios.	<code>nmap --randomize-hosts 192.168.1.0/24</code>

⚠ NOTA: Estas técnicas son para auditorías autorizadas donde necesitas evaluar también la efectividad de las defensas. Su uso no autorizado es ilegal.

5.3 Escaneos Especiales para Evadir Firewalls

Algunos tipos de escaneo generan paquetes 'inusuales' que ciertos firewalls anticuados no filtran correctamente:

FLAG	TIPO	¿QUÉ HACE?
-sN	NULL Scan	Envía paquetes sin ningún flag TCP. Los puertos cerrados responden con RST; los abiertos no responden.
-sF	FIN Scan	Solo activa el flag FIN (fin de conexión). Comportamiento similar al NULL Scan.
-sX	Xmas Scan	Activa los flags FIN, PSH y URG simultáneamente (parece un árbol de Navidad encendido).
-sA	ACK Scan	Envía paquetes ACK. Útil para determinar reglas de firewall (unfiltered vs filtered), no para detectar servicios.
-sW	Window Scan	Similar al ACK Scan pero analiza el tamaño de la ventana TCP para distinguir abierto de cerrado.

6. Casos Prácticos Paso a Paso

Esta sección muestra escenarios reales de uso de Nmap con explicaciones detalladas de cada comando y su resultado esperado.

Caso A: Descubrir qué dispositivos hay en tu red WiFi

Escenario: Quieres saber cuántos dispositivos están conectados a tu router en casa.

```
nmap -sn 192.168.1.0/24
```

Explicación del comando:

- **-sn**: Solo ping, no escanear puertos.
- **192.168.1.0/24**: Rango completo de tu red local (255 IPs posibles).

Resultado esperado:

```
Nmap scan report for 192.168.1.1
Host is up (0.003s latency).
MAC Address: AA:BB:CC:DD:EE:FF (TP-Link Technologies)

Nmap scan report for 192.168.1.5
Host is up (0.012s latency).
MAC Address: 11:22:33:44:55:66 (Apple)
```

El resultado muestra cada IP activa, su tiempo de respuesta y el fabricante del dispositivo (basado en la MAC address). Así puedes ver tu router, tu teléfono, tu smart TV, etc.

Caso B: Auditoría completa de un solo servidor

Escenario: Tienes autorización para auditar el servidor web de la empresa.

```
nmap -p- -sV -sC -O -T4 10.0.0.50 -oA auditoria_servidor
```

Explicación:

- **-p-**: Escanear los 65,535 puertos.
- **-sV**: Detectar versiones de servicios.
- **-sC**: Ejecutar scripts por defecto.
- **-O**: Detectar sistema operativo.
- **-T4**: Velocidad alta (red local rápida).
- **-oA auditoria_servidor**: Guardar en los 3 formatos (txt, xml, grep).

✓ CONSEJO: Este comando puede tardar varios minutos. El flag **-v** te permite ver el progreso en tiempo real.

Caso C: Búsqueda de vulnerabilidades críticas SMB

Escenario: Verificar si algún equipo de la red es vulnerable a EternalBlue (el exploit detrás de WannaCry).

```
nmap -p 445 --script smb-vuln-ms17-010 192.168.1.0/24
```

Si un equipo es vulnerable, verás:

```
Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|   State: VULNERABLE
```

⚠ NOTA: Si encuentras esto en tu red, PARCHEA INMEDIATAMENTE ese equipo con las actualizaciones de Windows. Esta vulnerabilidad fue usada por el ransomware WannaCry en 2017.

Caso D: Reconocimiento web completo

Escenario: Auditar el servidor web para obtener la máxima información posible.

```
nmap -p 80,443,8080,8443 -sV --script 'http-*' ejemplo.com
```

Esto ejecutará todos los scripts de Nmap relacionados con HTTP y revelará: versión del servidor, cabeceras de seguridad, métodos HTTP permitidos, directorios comunes, tecnologías usadas, y más.

Caso E: Auditoría sigilosa para evaluar defensas

Escenario: Comprobar si el IDS de la empresa detecta escaneos.

```
nmap -sS -T1 -D RND:5 --source-port 53 --data-length 15 192.168.1.1
```

Este comando combina múltiples técnicas de evasión para simular un atacante sofisticado y evaluar la efectividad de las defensas.

Caso F: Escaneo UDP de servicios de red

Escenario: Buscar servicios UDP mal configurados (SNMP con comunidad 'public', TFTP expuesto, etc.).

```
nmap -sU -p 53,67,68,69,123,161,162,500 --open 192.168.1.0/24
```

Los puertos más importantes en UDP son: 53 (DNS), 67/68 (DHCP), 69 (TFTP), 123 (NTP), 161/162 (SNMP).

✓ CONSEJO: Los escaneos UDP son mucho más lentos que TCP. Ten paciencia; puede tardar horas en rangos de red grandes.

7. Guía Completa de Puertos y Servicios

Esta tabla es tu referencia maestra. Cada puerto abierto es una potencial superficie de ataque que debes evaluar.

7.1 Puertos TCP Críticos

PUERTO	SERVICIO	PROTOCOLO	RIESGO DE SEGURIDAD	ACCIÓN RECOMENDADA
20/21	FTP	TCP	Alto: credenciales en texto plano. Posible acceso anónimo.	Migrar a SFTP (puerto 22). Deshabilitar FTP anónimo.
22	SSH	TCP	Medio: objetivo de fuerza bruta. Seguro si está bien configurado.	Usar autenticación por clave, no contraseña. Cambiar puerto por defecto.
23	Telnet	TCP	Crítico: TODO viaja en texto plano, incluyendo contraseñas.	Deshabilitar inmediatamente. Usar SSH en su lugar.
25	SMTP	TCP	Medio: puede ser relay abierto para spam. Enumeración de usuarios.	Autenticación obligatoria. Deshabilitar relay abierto.
53	DNS	TCP/UDP	Medio: transferencia de zona expone todos los registros DNS.	Restringir transferencias de zona a IPs autorizadas.
80	HTTP	TCP	Alto: tráfico no cifrado. Vector de ataques web (XSS, SQLi, etc.).	Forzar redirección a HTTPS (443). Usar WAF.
110	POP3	TCP	Alto: correo en texto plano.	Usar POP3S (995) con SSL/TLS.
135/139	RPC/NetBIOS	TCP	Alto: vector de movimiento lateral en redes Windows.	Bloquear en el perímetro. Limitar a subredes internas.
443	HTTPS	TCP	Bajo-Medio: cifrado pero puede tener vulnerabilidades en la app.	Mantener certificados actualizados. Revisar configuración SSL.
445	SMB	TCP	Crítico: EternalBlue, WannaCry. Movimiento lateral en redes.	Parchear siempre. Bloquear en el perímetro.
3306	MySQL	TCP	Alto: bases de datos expuestas a internet.	Nunca exponer a internet. Usar solo en localhost o red interna.
3389	RDP	TCP	Crítico: objetivo de ataques BlueKeep y de fuerza bruta.	No exponer directamente a internet. Usar VPN + NLA.

PUERTO	SERVICIO	PROTOCOLO	RIESGO DE SEGURIDAD	ACCIÓN RECOMENDADA
5432	PostgreSQL	TCP	Alto: igual que MySQL.	Mismas recomendaciones que MySQL.
6379	Redis	TCP	Crítico: sin autenticación por defecto. Ejecución remota posible.	Autenticación obligatoria. Nunca exponer a internet.
8080/8443	HTTP Alternativo	TCP	Alto: paneles de gestión como Jenkins, Tomcat. Credenciales por defecto.	Cambiar credenciales por defecto. Exponer solo en red interna.
27017	MongoDB	TCP	Crítico: sin autenticación por defecto en versiones antiguas.	Habilitar autenticación. Nunca exponer a internet.

7.2 Puertos UDP Importantes

PUERTO	SERVICIO	RIESGO
53	DNS	Transferencia de zona, envenenamiento de caché, amplificación DDoS.
67/68	DHCP	Servidor DHCP falso puede redirigir tráfico (DHCP Spoofing).
69	TFTP	Sin autenticación. Permite leer/escribir archivos sin credenciales.
123	NTP	Amplificación DDoS, manipulación de tiempo (ataques replay).
161/162	SNMP	Comunidad 'public' por defecto expone toda la información del dispositivo.
500	IKE/VPN	Negociación VPN. Mal configurada puede permitir ataques man-in-the-middle.
514	Syslog	Logs en texto plano, sin autenticación. Fácil falsificación de eventos.

8. Marco Legal y Ético

La ciberseguridad ética es fundamental. El conocimiento de estas herramientas conlleva responsabilidad. Un profesional de seguridad debe siempre actuar dentro del marco legal y ético.

8.1 ¿Qué es Legal y qué no?

SITUACIÓN	¿LEGAL?	EXPLICACIÓN
Escanear tu propia red doméstica	Sí	Tienes propiedad y control total sobre tus dispositivos.
Escanear servidores de tu empresa con autorización escrita	Sí	Con permiso documentado del propietario, es auditoría legítima.
Escanear un servidor de práctica en la nube (tuyo)	Sí	Es tu infraestructura.
Usar plataformas CTF (HackTheBox, TryHackMe)	Sí	Plataformas diseñadas específicamente para practicar.
Escanear la red de un vecino sin permiso	No	Es intrusión informática, delito penal.
Escanear servidores de empresas sin autorización	No	Delito grave en casi todos los países.
Escanear dispositivos del gobierno	No	Puede considerarse ataque a infraestructura crítica.

8.2 Marco Legal en Colombia

En Colombia, la Ley 1273 de 2009 (Ley de Delitos Informáticos) tipifica como delitos:

- **Artículo 269A:** Acceso abusivo a sistema informático — hasta 8 años de prisión.
- **Artículo 269C:** Interceptación de datos informáticos — hasta 3 años.
- **Artículo 269H:** Circunstancias de agravación (si se afectan servicios públicos o infraestructura crítica).

⚠ **NOTA:** Un escaneo de puertos sin autorización puede ser considerado 'acceso abusivo' y conllevar consecuencias penales. Siempre obtén autorización por escrito antes de realizar cualquier prueba.

8.3 El Proceso de Autorización

Antes de cualquier prueba de penetración o auditoría, debes obtener:

8. **Carta de Autorización:** Documento firmado por el representante legal de la organización.
9. **Alcance definido:** Exactamente qué IPs, dominios o sistemas están incluidos en la prueba.
10. **Ventana de tiempo:** Fechas y horas en que se realizarán las pruebas.
11. **Contacto de emergencia:** A quién llamar si algo sale mal durante la prueba.

12. **Reglas de compromiso:** Qué acciones están permitidas y cuáles están explícitamente prohibidas.

8.4 Dónde Practicar de Forma Legal

Existen plataformas diseñadas específicamente para practicar hacking ético de forma segura y legal:

- **Whoami Labs (whoami-labs.com):** Máquinas tipo Docker descargables para practicar offline.

✓ **CONSEJO:** Configura un laboratorio en casa con VirtualBox o VMware. Descarga Kali Linux y Metasploitable, y practica en un entorno completamente aislado de internet.

9. Flujo de Trabajo Completo de Auditoría

Una auditoría profesional con Nmap sigue una metodología estructurada. Aquí te presentamos el proceso completo, paso a paso.

Fase 1: Reconocimiento Pasivo

Antes de usar Nmap, recolecta información sin interactuar directamente con el objetivo:

```
# Verificar registros DNS públicos
nmap --dns-servers 8.8.8.8 -sL objetivo.com

# Descubrir subdominios con scripts NSE
nmap --script dns-brute objetivo.com
```

Fase 2: Descubrimiento de Hosts

Identifica qué equipos están activos:

```
# Descubrimiento básico sin escanear puertos
nmap -sn 192.168.1.0/24 -oG hosts_activos.txt

# Extraer solo las IPs activas del resultado
grep 'Up' hosts_activos.txt | awk '{print $2}' > ips_vivas.txt
```

Fase 3: Escaneo de Puertos

Escanear puertos en los hosts descubiertos:

```
# Escaneo rápido primero (top 1000 puertos)
nmap -T4 -iL ips_vivas.txt --open -oN escaneo_rapido.txt

# Escaneo completo de todos los puertos
nmap -p- -T4 -iL ips_vivas.txt -oA escaneo_completo
```

Fase 4: Detección de Servicios y Versiones

```
nmap -sV -sC -p [puertos abiertos] -iL ips_vivas.txt -oA servicios
```

Fase 5: Búsqueda de Vulnerabilidades

```
# Scripts de vulnerabilidades en servicios específicos
nmap --script vuln -p [puertos_abiertos] -iL ips_vivas.txt -oA vulnerabilidades

# Verificación de CVEs específicos conocidos
nmap -p 445 --script smb-vuln-ms17-010 -iL ips_vivas.txt
nmap -p 443 --script ssl-heartbleed -iL ips_vivas.txt
```

Fase 6: Documentación del Informe

Convierte los resultados XML a HTML para el informe:

```
xsltproc escaneo_completo.xml -o informe_auditoria.html
```

✓ **CONSEJO:** Siempre documenta cada hallazgo con: evidencia (captura del comando), impacto potencial, y recomendación de remediación. Un buen informe es tan importante como el escaneo mismo.

10. Cheat Sheet: Comandos de Referencia Rápida

Guarda esta sección para tenerla a mano durante tus auditorías.

10.1 Comandos Esenciales

OBJETIVO	COMANDO NMAP
Escaneo básico rápido	<code>nmap 192.168.1.1</code>
Detectar hosts en la red	<code>nmap -sn 192.168.1.0/24</code>
Escaneo de todos los puertos	<code>nmap -p- 192.168.1.1</code>
Detección de versiones + scripts	<code>nmap -sV -sC 192.168.1.1</code>
Escaneo agresivo completo	<code>nmap -A -p- 192.168.1.1</code>
Solo puertos abiertos	<code>nmap --open 192.168.1.0/24</code>
Guardar en todos los formatos	<code>nmap -oA resultado 192.168.1.1</code>
Buscar vulnerabilidades	<code>nmap --script vuln 192.168.1.1</code>
Escaneo UDP	<code>nmap -sU -p 161,53,67 192.168.1.1</code>
Escaneo silencioso	<code>nmap -sS -T1 -f 192.168.1.1</code>
Top 100 puertos	<code>nmap --top-ports 100 192.168.1.1</code>
Escanear lista de IPs	<code>nmap -iL lista_ips.txt</code>
Detección de OS	<code>nmap -O 192.168.1.1</code>
Script HTTP completo	<code>nmap -p 80,443 --script 'http-*' 192.168.1.1</code>
EternalBlue en toda la red	<code>nmap -p 445 --script smb-vuln-ms17-010 192.168.1.0/24</code>

11. Conclusión y Próximos Pasos

Has completado el manual básico de Nmap. Con esto tienes las herramientas conceptuales y prácticas para comenzar a hacer auditorías de red de forma ética y profesional.

¿Qué aprender después de Nmap?

- **Metasploit Framework:** Para explotar vulnerabilidades encontradas con Nmap en entornos autorizados.
- **Wireshark:** Para analizar el tráfico de red en tiempo real.
- **Burp Suite:** Para auditar aplicaciones web.

Recuerda: el hacking ético es una profesión en crecimiento con alta demanda. La diferencia entre un hacker malicioso y un profesional de ciberseguridad es una sola cosa: el permiso.

⚠ **NOTA:** Nunca dejes de aprender. Las amenazas evolucionan constantemente, y los defensores deben ir siempre un paso adelante.